

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 — NVD CVSS-weighted Risk Scoring · Generated: 2026-06-13 · SHA: `61ed8c3` · Model: `0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality`

Risk Band Summary

Band	Count
CRITICAL	1
HIGH	6
MEDIUM	4
LOW	0

Ranked Remediation Backlog

#	Coordinate	Ver	Band	Risk Score	CVE Sev	Exposure	Criticality	Top CVE / Issue	Fix Version
1	com.fasterxml.jackson.core:jackson-databind	2.9.8	CRITICAL	8.0	10.0	8.0	3.0	CVE-2019-14379 (9.8)	2.9.9.1
2	org.apache.logging.log4j:log4j-core	2.14.1	HIGH	7.8	10.0	8.0	2.0	CVE-2021-44228 (10.0)	2.15.0
3	com.fastxml.jackson.core:jackson-databind	2.9.8	HIGH	7.5	9.0	8.0	3.0	TYPOSQUAT (REMOVE)	—
4	org.apache.logging.log4j:log4j-api	2.14.1	HIGH	6.8	7.5	8.0	2.0	CVE-2026-34479 (7.5)	2.25.4
5	mysql:mysql-connector-java	8.0.30	HIGH	6.7	8.3	7.0	2.0	CVE-2023-22102 (8.3)	8.1.1
6	com.google.protobuf:protobuf-java	3.19.4	HIGH	6.7	7.5	8.0	2.0	CVE-2024-7254 (7.5)	3.25.5
7	com.google.guava:guava	24.1.1-jre	HIGH	6.3	7.1	7.0	2.0	CVE-2023-2976 (7.1)	32.0.0-jre
8	com.fasterxml.jackson.core:jackson-annotations	2.9.0	MEDIUM	5.7	6.5	5.0	3.0	CVE-2018-1000873 (6.5)	2.9.8
9	commons-io:commons-io	2.4	MEDIUM	5.2	5.3	7.0	2.0	CVE-2021-29425 (4.8)	2.7
10	org.apache.commons:commons-lang3	3.4	MEDIUM	5.2	5.3	7.0	2.0	CVE-2025-48924 (5.3)	3.18.0
11	REPO:internal-untrusted-mirror	—	MEDIUM	4.9	6.0	5.0	2.0	UNTRUSTED_REPO (HTTP)	Remove

Component Score Detail

Dependency	CVE Count	Max CVSS	CVE Severity Score	Exposure	Business Criticality	Risk Score	Band
jackson-databind:2.9.8	53	9.8	10.0 (+density)	8.0 (direct, compile, serialization)	3.0 (API layer)	8.0	CRITICAL

log4j-core:2.14.1	8	10.0	10.0 (capped)	8.0 (direct, compile, logging)	2.0 (internal service)	7.8	HIGH
com.fastxml...:jackson-databind:2.9.8	0 (typosquat)	—	9.0 (supply-chain CRITICAL)	8.0 (direct, compile)	3.0 (API impersonation)	7.5	HIGH
log4j-api:2.14.1	2	7.5	7.5	8.0 (direct, compile, logging)	2.0 (internal service)	6.8	HIGH
mysql-connector-java:8.0.30	1	8.3	8.3	7.0 (direct, compile)	2.0 (data layer)	6.7	HIGH
protobuf-java:3.19.4	4	7.5	8.5 (+density)	8.0 (transitive, compile)	2.0 (data layer)	6.7	HIGH
guava:24.1.1-jre	2	7.1	7.6 (+density)	7.0 (direct, compile)	2.0 (internal)	6.3	HIGH
jackson-annotations:2.9.0	1	6.5	6.5	5.0 (transitive, compile)	3.0 (API layer)	5.7	MEDIUM
commons-io:2.4	2	4.8	5.3 (+density)	7.0 (direct, compile)	2.0 (internal)	5.2	MEDIUM
commons-lang3:3.4	1	5.3	5.3	7.0 (direct, compile)	2.0 (internal)	5.2	MEDIUM

Scoring formula: risk_score = round(0.5 × cve_severity + 0.3 × exposure + 0.2 × business_criticality, 1)

Band thresholds: CRITICAL ≥ 8.0 · HIGH 6.0–7.9 · MEDIUM 3.0–5.9 · LOW < 3.0

Floor rule: any dependency carrying at least one CRITICAL CVE is floored to band HIGH, regardless of weighted score.

Supply-Chain Risk Items

CRITICAL — Typosquatted dependency: `com.fastxml.jackson.core:jackson-databind:2.9.8`. The groupId `com.fastxml` is a letter-transposition typosquat of `com.fasterxml.jackson.core`. This coordinate does not exist on Maven Central and fails resolution. Risk score 7.5 (HIGH band) — supply-chain CRITICAL override. **Action: remove this dependency block from `pom.xml` with no replacement.** The legitimate `com.fasterxml.jackson.core:jackson-databind` is already declared in the same file.

HIGH — Plain-HTTP repository `internal-untrusted-mirror` (`http://insecure-mirror.example.net/maven2`). Maven's default HTTP mirror blocker already rejects this repository. However, its presence in `pom.xml` indicates intent to use an unauthenticated, unencrypted source. Any artifact served over plain HTTP can be substituted in transit. Risk score 4.9 (MEDIUM). **Action: remove the `<repository>` block entirely.**

Priority Recommendations

- P0 — Remove typosquat immediately.** Delete `com.fastxml.jackson.core:jackson-databind:2.9.8` from `pom.xml`. This is a confirmed supply-chain attack vector — no upgrade path exists, removal is the only action.
- P0 — Upgrade `jackson-databind` to 2.18.3.** 53 CVEs including 14 CRITICAL RCE deserialization gadget chains. This is the highest-scoring scanned dependency (risk 8.0, CRITICAL band). The safe minimum is 2.13.4.2; recommend latest stable 2.18.x.
- P0 — Upgrade `log4j-core` and `log4j-api` to 2.24.3.** CVE-2021-44228 (Log4Shell, CVSS 10.0) is actively exploited in the wild. Minimum safe version is 2.17.1; recommend latest 2.24.x for all 2026 CVE fixes. Risk 7.8 (HIGH band, CRITICAL CVE floor).
- P1 — Upgrade `mysql-connector-java` to 8.1.1+ and resolve GPL-2.0 license violation.** CVE-2023-22102 (CVSS 8.3 HIGH) plus a license compliance issue. Consider migrating to `com.mysql:mysql-connector-j:9.x`.
- P1 — Upgrade `protobuf-java` (transitive via `mysql`).** 4 HIGH CVEs including DoS via crafted input. Fix: 3.25.5. Resolved when `mysql-connector-java` is updated to a version depending on `protobuf-java` 3.25.5+.
- P1 — Upgrade `guava` to 33.4.0-jre.** CVE-2023-2976 (CVSS 7.1 HIGH) — symlink-based temp directory privilege escalation. This is a major version bump; review API compatibility.
- P2 — Remove plain-HTTP repository `internal-untrusted-mirror`.** Delete the `<repository>` block for `http://insecure-mirror.example.net/maven2`.

8. **P3 — Routine upgrades.** `commons-io` → 2.18.0 (fixes 2 MEDIUM CVEs), `commons-lang3` → 3.18.0 (fixes CVE-2025-48924), `jackson-annotations` → 2.18.3 (transitive, upgraded automatically with jackson-databind).

Machine-readable source: `depscan-risk-report.json` · Generated by the Dependency & Supply-Chain Plugin — Stage 2 · Source SHA: `61ed8c3140d76e3a19a88954e834d39c9f7635fb`